Microsoft 365 Copilot Secure Adoption & Governance

Implementation Solution Guide

Version 1.0.0 · 2026-07-01

Contents

Executive Summary — Microsoft 365 Copilot Secure Adoption & Governance 4

What you get . . . 4

What this delivers . . . 4

The deployment model . . . 4

Outcome . . . 4

1. Solution Overview — Microsoft 365 Copilot Secure Adoption & Governance 5

What Microsoft 365 Copilot is . . . 5

How it accesses data (and why oversharing is the top risk) . . . 5

What constrains Copilot (the controls this solution configures) . . . 5

AI governance (the human controls) . . . 6

Benefits . . . 6

Limitations (be honest with buyers) . . . 6

The deployment model . . . 7

2. Requirements Guide — Microsoft 365 Copilot Secure Adoption & Governance 7

2.1 Microsoft 365 Copilot licensing . . . 7

2.2 Microsoft 365 with SharePoint Online / OneDrive . . . 7

2.3 Microsoft Purview (sensitivity labels + DLP) . . . 7

2.4 SharePoint / OneDrive access review (oversharing assessment) . . . 7

2.5 Sensitivity labels published (or ready to publish) . . . 8

2.6 Governance roles / administrative access . . . 8

2.7 Copilot pilot group . . . 8

2.8 AI governance / acceptable-use policy . . . 8

2.9 Change control for data-access and AI-enablement changes . . . 8

Checklist . . . 8

3. Implementation Guide — Microsoft 365 Copilot Secure Adoption & Governance 9

Step 1 — Assess oversharing and access (read-only) . . . 9

Step 2 — Remediate oversharing (restrict broad access) . . . 9

Step 3 — Publish sensitivity labels (protection Copilot honors) . . . 10

Step 4 — Configure DLP and Copilot data controls . . . 10

Step 5 — Create the Copilot pilot group . . . 10

Step 6 — Set AI-governance guardrails (acceptable use + admin controls) . . . 11

Step 7 — Enable Copilot for the pilot . . . 11

Step 8 — Validate the pilot . . . 11

Step 9 — Expand to production . . . 11

5. Testing Guide — Microsoft 365 Copilot Secure Adoption & Governance 12

Test 1 — Oversharing remediated on targeted sites . . . 12
Test 2 — Sensitivity labels published and applied . . . 12
Test 3 — Copilot licensing limited to the pilot . . . 12
Test 4 — Exposure probe: restricted content is NOT surfaced . . . 12
Test 5 — Exposure probe: label protection is honored in output . . . 12
Test 6 — DLP-for-Copilot exclusion works . . . 12
Test 7 — Data-exposure numbers improved . . . 13
Pass/fail gate . . . 13
6. Troubleshooting Guide — Microsoft 365 Copilot Secure Adoption & Governance 13
A. Copilot surfaces content it shouldn't . . . 13
B. Sensitivity labels not honored . . . 13
C. DLP-for-Copilot not excluding content . . . 14
D. Legitimate work is now blocked (over-remediation) . . . 14
E. Copilot not working for a pilot user . . . 14
F. Diagnostics quick reference . . . 14
G. When to escalate . . . 15
7. Best Practices — Microsoft 365 Copilot Secure Adoption & Governance 15
8. Deliverables Summary — Microsoft 365 Copilot Secure Adoption & Governance 16
Documentation . . . 16
PowerShell scripts . . . 16
What the buyer receives . . . 17
Outcome . . . 17
Appendix A — PowerShell Scripts 18

Executive Summary — Microsoft 365 Copilot Secure Adoption & Governance

Microsoft 365 Copilot is only as safe as the data it can see — and it can see everything the signed-in user can. Turn it on before you have fixed oversharing, missing sensitivity labels, and weak access controls, and it will happily surface confidential files, HR data, and stale content to anyone who asks a question. The risk is not a Copilot bug; it is your existing data estate, suddenly made searchable in natural language.

This is a complete, deploy-it-in-order package for adopting Microsoft 365 Copilot securely, written for an administrator who has not run a data-governance program before. It gives you the repeatable way to assess and remediate oversharing, apply sensitivity labels and DLP so Copilot respects them, tighten access, put AI governance and acceptable-use guardrails in place, and prove it all on a controlled pilot before you scale.

What you get

• A plain-language Solution Overview of how Copilot reads M365 data (the user's permissions plus the semantic index), why oversharing is the top risk, and how labels, DLP, and search controls constrain what Copilot can surface.

• A Requirements Guide with verify / implement-if-missing for every prerequisite — Copilot licensing, Microsoft 365 and Purview, Entra ID, a SharePoint/OneDrive access review, sensitivity labels, a pilot group, and named governance owners.

• An Implementation Guide of precise, ordered steps across the Microsoft 365 admin center, Microsoft Purview, and the SharePoint admin center — in the required order.

• Five PowerShell scripts for readiness and oversharing discovery, per-scope access and label validation, a data-exposure and readiness report, safe remediation of oversharing, and a Copilot pilot scope-group builder.

• Testing and Troubleshooting guides with explicit pass/fail gates for a confident rollout.

What this delivers

Microsoft 365 Copilot rolled out on a governed data estate — oversharing remediated, sensitivity labels and DLP enforced so Copilot honors them, access tightened, restricted SharePoint search and Copilot data controls applied, and AI use governed by an acceptable-use policy and admin controls — proven on a controlled pilot before you expand.

The deployment model

Assess → **Configure** → **Pilot** → **Validate** → **Expand** — with a pilot gate and a rollback at every stage.

Outcome

A secure Copilot adoption a single administrator can run and defend at audit: the top risk (oversharing) assessed and fixed first, protection Copilot actually respects, and AI use governed — validated on a pilot

before the fleet ever gets access.

1. Solution Overview — Microsoft 365 Copilot Secure Adoption & Governance

What Microsoft 365 Copilot is

Microsoft 365 Copilot is an AI assistant that answers questions and generates content by reasoning over your organization's Microsoft 365 data — files in SharePoint and OneDrive, emails, Teams chats, and calendar. It grounds its answers using the **Microsoft Graph** and the **semantic index** (a meaning-based index of your tenant content) through an orchestration Microsoft calls **retrieval**. The critical property to understand: Copilot only ever returns content the **signed-in user already has permission to open**. It does not grant new access — but it makes everything a user *can* reach instantly findable in plain language.

How it accesses data (and why oversharing is the top risk)

1. A user asks Copilot a question.

2. Copilot searches the semantic index and Graph **as that user**, honoring existing SharePoint,

OneDrive, and Exchange permissions.

1. It retrieves the content the user is permitted to see, reasons over it, and returns an answer

with citations back to the source items.

1. Because retrieval respects — and is therefore limited only by — existing permissions, any file a

user *could technically* open (even one they never knew existed) can now be surfaced by a simple question. This is **oversharing**: broad or stale access that was survivable when nobody browsed for it becomes a live data-exposure path the moment Copilot makes it searchable.

The rule of thumb: `Copilot exposure = what the user can access`. Fix the access, and you fix the exposure. That is why this solution assesses and remediates the data estate **before** enabling Copilot.

What constrains Copilot (the controls this solution configures)

• **SharePoint / OneDrive sharing and permissions.** The primary control. Removing broad

"Everyone / Everyone except external users", org-wide links, and stale guest access shrinks what Copilot can surface. This is the highest-leverage remediation.

• **Sensitivity labels (Microsoft Purview).** Labels classify content and can **encrypt** it and set

usage rights. Copilot **honors** label-based access: if a user cannot open an encrypted item, Copilot cannot use it for that user, and Copilot-generated content **inherits** the most restrictive label of its sources. Labels also drive extract/copy rights that flow into Copilot responses.

• **Data Loss Prevention (DLP).** A DLP policy scoped to Copilot can **exclude labeled content** from

being processed or summarized by Copilot, adding a policy layer on top of labels.

• **Restricted SharePoint Search / Copilot data controls.** A tenant control that limits Copilot (and organization-wide search) to an **allowed list of curated sites** while you remediate the rest — a temporary containment measure so you can pilot safely before oversharing is fully fixed.

• **Access reviews and lifecycle.** Entra access reviews and site lifecycle keep permissions from drifting back to oversharing after you remediate.

AI governance (the human controls)

• **Acceptable-use policy** for Copilot: what it may/may not be used for, data-handling expectations, and review of AI-generated output before it is trusted or shared.

• **Admin controls** in the Microsoft 365 admin center and Copilot admin experience: who is licensed, which users are in the pilot, and (where available) web-grounding and plugin/agent controls.

• **Named owners** for data governance, labels/DLP, and AI use — governance is a role, not a one-time task.

Benefits

• **Data safety** — the top risk (oversharing) is assessed and fixed before Copilot can exploit it.

• **Protection Copilot respects** — sensitivity labels and DLP constrain what Copilot surfaces and what its output inherits.

• **Controlled blast radius** — restricted search and a phased pilot mean a small, curated scope goes first, not the whole tenant.

• **Governed AI** — acceptable-use and admin controls put humans in charge of how Copilot is used.

• **Repeatable and auditable** — a documented Assess → Configure → Pilot → Validate → Expand process.

Limitations (be honest with buyers)

• Copilot honors permissions **as they are** — it will not fix oversharing for you; the remediation is the work, and this solution front-loads it.

• Sensitivity labels only help where content is **actually labeled**; unlabeled files rely on permissions and search controls alone until labeling catches up.

• Restricted SharePoint Search is a **containment** measure, not a permanent architecture — it narrows Copilot but also narrows legitimate search; plan to remediate and lift it.

• Some Copilot admin and DLP-for-Copilot controls evolve quickly; portal-specific toggles are noted generically here and **volatile specifics are deferred to Microsoft's documentation**.

• Copilot licensing is a paid add-on with prerequisites — confirm licensing before you begin.

The deployment model

> ***Assess oversharing and access → Configure labels, DLP, search controls, and AI governance → Pilot with a curated group → Validate exposure and behavior → Expand.*** *The pattern is* ***Assess → Configure → Pilot → Validate → Expand****, with a pilot gate and rollback.*

2. Requirements Guide — Microsoft 365 Copilot Secure Adoption & Governance

Verify **every** requirement before configuring. Each entry: **Description · Why · Verify · Implement-if-missing.** Category-wide prerequisites are in `global-requirements-security.md`.

2.1 Microsoft 365 Copilot licensing

Description: A Microsoft 365 Copilot license for each pilot user, on a qualifying base plan. **Why:** Copilot only functions for licensed users; the license is a paid add-on with base-plan prerequisites. **Verify:** Microsoft 365 admin center (`https://admin.microsoft.com`) → **Billing** → **Licenses**; confirm Microsoft 365 Copilot licenses are available and unassigned enough for the pilot. **Implement:** Acquire Microsoft 365 Copilot licenses on a qualifying Microsoft 365 plan; do **not** assign them broadly yet — assignment is gated to the pilot group in Implementation.

2.2 Microsoft 365 with SharePoint Online / OneDrive

Description: SharePoint Online and OneDrive as the content estate Copilot will reason over. **Why:** SharePoint/OneDrive sharing is the primary control surface for oversharing — the top risk. **Verify:** SharePoint admin center (`https://<tenant>-admin.sharepoint.com`) loads; sites and OneDrive are present. **Implement:** Ensure Microsoft 365 with SharePoint/OneDrive is provisioned before assessing access.

2.3 Microsoft Purview (sensitivity labels + DLP)

Description: Microsoft Purview access to publish sensitivity labels and Data Loss Prevention policies. **Why:** Labels are the protection Copilot honors; DLP-for-Copilot adds a policy layer that can exclude content. **Verify:** Microsoft Purview portal (`https://purview.microsoft.com`) → **Information Protection** and **Data Loss Prevention** load. **Implement:** Confirm a plan that includes sensitivity labels and DLP (e.g. Microsoft 365 E5 / E5 Compliance, or equivalent); assign the operator the required Purview roles.

2.4 SharePoint / OneDrive access review (oversharing assessment)

Description: A completed review of broad sharing: org-wide links, "Everyone / Everyone except external users", and stale external/guest access. **Why:** This is exactly what Copilot will surface; it must be assessed and remediated before enabling Copilot. **Verify:** Run `COPILOT-Discovery.ps1` (reports broad-sharing and external-access signals) and review `COPILOT-Report.ps1` output. **Implement:** Complete the access review in Implementation Steps 1–2 (assess, then remediate) before the pilot gate.

2.5 Sensitivity labels published (or ready to publish)

Description: A sensitivity-label taxonomy (e.g. Public / Internal / Confidential / Highly Confidential) published to users, with protection where required. **Why:** Copilot honors label-based access and inherits the most restrictive label of its sources; unlabeled content relies on permissions alone. **Verify:** Purview → **Information Protection** → **Labels** and **Label policies** show published labels. **Implement:** Create and publish the label taxonomy in Implementation Step 3; apply auto-labeling where available.

2.6 Governance roles / administrative access

Description: The operator holds the roles needed for Copilot, SharePoint, and Purview changes. **Why:** Enabling Copilot, editing sharing controls, and publishing labels/DLP require elevated, scoped rights. **Verify:** Entra → **Roles and administrators**; confirm roles such as SharePoint Administrator and the required Purview/Compliance roles (reserve Global Administrator for tenant-wide toggles). **Implement:** Assign least-privilege roles for each surface; record who owns data governance, labels/DLP, and AI use.

2.7 Copilot pilot group

Description: An Entra security group `Copilot Adoption – Pilot Users – Pilot` for the controlled rollout. **Why:** Copilot must be validated on a small, curated group before fleet expansion (pilot gate + rollback). **Verify:** Entra → **Groups**; the pilot group exists. Or run `COPILOT-Set-ScopeTargeting.ps1`. **Implement:** Create the group with `COPILOT-Set-ScopeTargeting.ps1` (or Entra → **Groups** → **New group** → **Security**), and add a few representative users.

2.8 AI governance / acceptable-use policy

Description: A documented acceptable-use policy for Copilot and named governance owners. **Why:** AI use must be governed by humans — what Copilot may be used for, output review, and data handling. **Verify:** An acceptable-use policy exists and is communicated to pilot users; owners are named. **Implement:** Draft and publish the acceptable-use policy in Implementation Step 6 before pilot users get access.

2.9 Change control for data-access and AI-enablement changes

Description: A documented change/rollback process for sharing-control, label, DLP, and Copilot-enablement changes. **Why:** Tightening access or changing labels can block legitimate work; enabling Copilot changes the data-exposure surface. A pilot gate and rollback are mandatory (see global G8). **Verify:** A change ticket exists with an approver, a maintenance window, and a rollback step. **Implement:** Record the change, name the pilot group, define the rollback (e.g. re-widen a link, unpublish a label, remove Copilot licenses), and get approval before production.

Checklist

- Microsoft 365 Copilot licenses available (not yet broadly assigned)
- SharePoint Online / OneDrive provisioned

- Microsoft Purview (sensitivity labels + DLP) available with operator roles
- Oversharing assessment run — `COPILOT-Discovery.ps1` / `COPILOT-Report.ps1`
- Sensitivity-label taxonomy published (or ready to publish)
- Governance/admin roles assigned (SharePoint, Purview, Copilot)
- `Copilot Adoption – Pilot Users – Pilot` group created
- Acceptable-use policy drafted and owners named
- Change control / rollback documented

3. Implementation Guide — Microsoft 365 Copilot Secure Adoption & Governance

Follow these steps **in order**, across three portals: the **Microsoft 365 admin center** (`https://admin.microsoft.com`), **Microsoft Purview** (`https://purview.microsoft.com`), and the **SharePoint admin center** (`https://<tenant>-admin.sharepoint.com`).

> ***Model:*** *Assess and remediate the data estate **first**, configure the protection Copilot honors, govern AI use, then enable Copilot for a small curated pilot, validate exposure, and only then expand. Copilot exposure equals what the user can access — so access is fixed before Copilot is on.*

Name every object exactly as shown, in the form `<Purpose> – <Scope> – <Stage>`, and reuse the names verbatim across scripts, assignments, and reports.

Step 1 — Assess oversharing and access (read-only)

1. Run `COPILOT-Discovery.ps1` to enumerate broad sharing and Copilot-readiness signals: sites and

OneDrive with org-wide / "Everyone except external users" links, anonymous/anyone links, external (guest) access, and whether sensitivity labels exist.

1. Run `COPILOT-Report.ps1` to produce the data-exposure and readiness summary (how much content is

broadly shared, externally shared, and unlabeled).

1. In the SharePoint admin center → **Policies** → **Sharing**, note the tenant and per-site external

sharing posture. In **Sites** → **Active sites**, sort by external sharing to find the widest sites.

1. Record the highest-risk sites/links as the remediation worklist. **Do not enable Copilot yet.**

Step 2 — Remediate oversharing (restrict broad access)

1. Review the remediation worklist from Step 1 with the site/content owners (do not silently remove

access people rely on).

1. Run `COPILOT-Remediation.ps1` in its default `-WhatIf` mode to preview the changes it would make

(removing anonymous/org-wide links and flagging broad grants). Review the preview with owners.

1. Re-run `COPILOT-Remediation.ps1 -Apply` to remove anonymous/"anyone" links and org-wide links on

the targeted scope. Broad group grants (e.g. "Everyone except external users") are **reported for owner action**, not silently deleted.

1. In the SharePoint admin center → **Policies** → **Sharing**, tighten the tenant default (e.g. move

from "Anyone" to "New and existing guests" or "Only people in your organization" where policy allows) and set a default link type of "Specific people".

1. Clean up stale guest access via Entra → **Identity governance** → **Access reviews** for guests, and

via the site-level **Site permissions**.

Step 3 — Publish sensitivity labels (protection Copilot honors)

1. In Microsoft Purview → **Information Protection** → **Labels**, create the taxonomy, for example:

`Public`, `Internal`, `Confidential`, and `Highly Confidential`. Apply **encryption and usage rights** on the protected labels so only entitled users can open the content.

1. Go to **Information Protection** → **Label policies** → **Publish labels**, publish to your users

(start with the pilot scope), and set a **default label** and mandatory-labeling behavior per policy.

1. Where available, configure **auto-labeling** (service-side) to classify sensitive content at scale

so protection does not depend on every user labeling by hand.

1. Confirm intent: Copilot will not surface encrypted content to users who lack rights, and

Copilot-generated output **inherits** the most restrictive source label.

Step 4 — Configure DLP and Copilot data controls

1. In Purview → **Data Loss Prevention** → **Policies** → **Create policy**, scope a policy that targets the

Microsoft 365 Copilot location (where available) and configure it to **exclude labeled content** (e.g. `Highly Confidential`) from being processed/summarized by Copilot. Name it `Copilot Data Exclusion – Highly Confidential – Pilot`.

1. Start the DLP policy in **test / simulation mode**, review matches, then turn it on for the pilot scope.

2. Apply **Restricted SharePoint Search** (or the current Copilot data-control equivalent) as a

temporary containment: limit Copilot and org-wide search to a curated **allowed list of sites** while remaining oversharing is being remediated. Note this narrows legitimate search too — treat it as temporary and lift it as remediation completes. Portal-specific toggles for these controls are volatile; defer exact navigation to Microsoft's documentation.

Step 5 — Create the Copilot pilot group

1. Run `COPILOT-Set-ScopeTargeting.ps1` (default `-WhatIf`) to preview, then `-Apply` to create

`Copilot Adoption – Pilot Users – Pilot` (reused if it already exists).

1. Add a few representative pilot users (mix of roles) to the group. Do not add the whole org.

Step 6 — Set AI-governance guardrails (acceptable use + admin controls)

1. Publish the **acceptable-use policy** for Copilot to the pilot users: permitted uses, the requirement to review AI-generated output before trusting/sharing it, and data-handling expectations. Name the governance owners.

1. In the Microsoft 365 admin center → **Copilot** admin experience, review the available organization controls (licensed users, and where available web-grounding and plugin/agent settings). Set them to the conservative pilot posture. Defer volatile portal specifics to Microsoft documentation.

Step 7 — Enable Copilot for the pilot

1. In the Microsoft 365 admin center → **Billing** → **Licenses** → **Microsoft 365 Copilot**, assign Copilot licenses **only** to the members of `Copilot Adoption – Pilot Users – Pilot` (group-based licensing is preferred so scope stays tied to the group).

1. Confirm the DLP-for-Copilot policy, labels, and restricted-search scope are active for the pilot.

Step 8 — Validate the pilot

1. Run `COPILOT-Validation.ps1` to confirm, per scope: broad-sharing links removed on the targeted sites, labels published/applied, and Copilot licenses limited to the pilot group.

1. Run `COPILOT-Report.ps1` to confirm the data-exposure numbers moved in the right direction (fewer broadly/externally shared items, more labeled content).

1. Perform the exposure probes in the **Testing Guide** (ask Copilot, as a pilot user, for content it should **not** be able to surface, and confirm it cannot). Complete the pilot gate.

Step 9 — Expand to production

1. Only after the pilot passes: widen the remediated scope, lift **Restricted SharePoint Search** containment as sites are cleaned, and expand label/DLP policies from the pilot scope to broader scopes.

1. Grow the pilot group (or add production groups) and assign Copilot licenses in controlled waves, re-running `COPILOT-Report.ps1` after each wave.

1. Stand up recurring **access reviews** and re-run `COPILOT-Discovery.ps1` on a schedule so oversharing does not drift back after Copilot is live.

Order of operations

```
Assess oversharing → Remediate sharing → Publish labels → DLP + search
controls → Pilot group → AI governance → Enable Copilot (pilot) → Validate
```

→ Expand

5. Testing Guide — Microsoft 365 Copilot Secure Adoption & Governance

Run after the pilot is configured and Copilot is enabled for the pilot group (Implementation Step 8), and re-run after each expansion wave. The most important tests are the **exposure probes** — proving Copilot cannot surface what it should not.

Test 1 — Oversharing remediated on targeted sites

Do: Run `COPILOT-Discovery.ps1`; review the broad-sharing signals for the remediated sites. **Expected:** Anonymous/"anyone" and org-wide links are gone on the targeted sites; remaining broad grants are only those owners explicitly approved.

Test 2 — Sensitivity labels published and applied

Do: Purview → **Information Protection** → **Label policies**; confirm the taxonomy is published to the pilot. Run `COPILOT-Validation.ps1`. **Expected:** Labels are published; protected labels carry encryption/usage rights; auto-labeling (if configured) is applying to sample content.

Test 3 — Copilot licensing limited to the pilot

Do: Run `COPILOT-Validation.ps1` (checks Copilot license assignment against the pilot group). **Expected:** Copilot licenses are assigned only to members of `Copilot Adoption – Pilot Users – Pilot` — not the whole org.

Test 4 — Exposure probe: restricted content is NOT surfaced

Do: As a **pilot user who should not have access**, ask Copilot for content in a restricted/labeled or non-shared site (e.g. "summarize the HR compensation files"). **Expected:** Copilot returns nothing from that content — it honors permissions and label-based access. No citations to content the user cannot open.

Test 5 — Exposure probe: label protection is honored in output

Do: As a pilot user, ask Copilot to summarize a document carrying a protected label the user *can* open, then attempt to reuse the output. **Expected:** Copilot-generated output inherits the most restrictive source label; protected content is not stripped of its label.

Test 6 — DLP-for-Copilot exclusion works

Do: As a pilot user, ask Copilot to summarize content that the `Copilot Data Exclusion – Highly Confidential – Pilot` policy excludes. **Expected:** The excluded content is not processed/summarized by Copilot for that request.

Test 7 — Data-exposure numbers improved

Do: Run `COPILOT-Report.ps1` and compare against the Step 1 baseline. **Expected:** Fewer broadly/externally shared items and more labeled content than the pre-remediation baseline.

Pass/fail gate

Gate	Requirement
Pilot pass	Tests 1–4 pass; the exposure probe (Test 4) confirms restricted content is not surfaced; licensing is pilot-only
Expand pass	Tests 1–3, 6, 7 pass for the newly remediated scope before the next license wave

6. Troubleshooting Guide — Microsoft 365 Copilot Secure Adoption & Governance

Use `COPILOT-Discovery.ps1` / `COPILOT-Validation.ps1` for the current state, `COPILOT-Report.ps1` for the data-exposure picture, and `COPILOT-Remediation.ps1` (default `-WhatIf`) for safe fixes.

A. Copilot surfaces content it shouldn't

Symptom	Cause	Remediation
Copilot returns confidential/HR/stale files to a user	Oversharing — the user actually has access via a broad or org-wide link	Run `COPILOT-Discovery.ps1` to find the broad grants; run `COPILOT-Remediation.ps1 -Apply` to remove anonymous/org-wide links; tighten site permissions
Sensitive site still surfaced during pilot	Remediation not yet complete on that site	Add the site to the **Restricted SharePoint Search** allowed-list containment until it's remediated; then lift
Guest surfaced internal content via Copilot	Stale external/guest access	Run an Entra access review for guests; remove stale guest grants; tighten tenant external-sharing policy

B. Sensitivity labels not honored

Symptom	Cause	Remediation
Copilot uses content that should be blocked by a label	The label carries no encryption/usage rights, or the content is unlabeled	Confirm the protected label applies encryption; run/verify auto-labeling; label-based access only constrains Copilot where content is actually labeled and protected
Copilot output lost its source label	Output-inheritance not evaluated as expected	Confirm labels are published to the user and the source item is protected; re-test per Testing Test 5

C. DLP-for-Copilot not excluding content

• Confirm the policy targets the **Microsoft 365 Copilot** location and is **on** (not still in test/simulation). Confirm the excluded label matches the content's label exactly. Give policy changes time to propagate before re-testing.

D. Legitimate work is now blocked (over-remediation)

• If tightening sharing or restricted search blocked people who need access: re-grant via specific people/groups (not broad links), add the site to the restricted-search allowed list, or unpublish an over-aggressive label policy from the affected scope. Use the change-control rollback (global G8).

E. Copilot not working for a pilot user

Symptom	Cause	Remediation
Pilot user has no Copilot	License not assigned or user not in the pilot group	Confirm membership of `Copilot Adoption – Pilot Users – Pilot`; assign the Copilot license (group-based licensing preferred)
Copilot answers with no tenant grounding	Base-plan/prerequisite or indexing not ready	Confirm the qualifying base plan and that content has been indexed; allow time after enablement

F. Diagnostics quick reference

```
# Read-only signals and exposure baseline
.\COPILOT-Discovery.ps1
.\COPILOT-Report.ps1

# Confirm remediation held (broad links removed, labels published, licensing pilot-only)
.\COPILOT-Validation.ps1

# Preview safe remediation before applying
.\COPILOT-Remediation.ps1 -WhatIf
```

Portal checks: SharePoint admin center → **Sites** → **Active sites** (sort by external sharing); Microsoft Purview → **Information Protection** (labels) and **Data Loss Prevention** (policies); Microsoft 365 admin

center → **Billing** → **Licenses** (Copilot assignment) and the **Copilot** admin experience.

G. When to escalate

If oversharing is remediated, labels are published and honored, DLP is on for the Copilot location, licensing is pilot-only, and Copilot still surfaces content it should not — capture the exact prompt, the citing item, and the user's effective permissions on that item, and open a Microsoft support case. Volatile Copilot-portal and DLP-for-Copilot specifics are deferred to Microsoft's documentation.

7. Best Practices — Microsoft 365 Copilot Secure Adoption & Governance

- **Fix oversharing first, then turn on Copilot.** Copilot exposure equals what the user can access — remediating broad sharing is the single most important thing you do, and it must come before enablement, not after.
- **Assess with data, not assumptions.** Run `COPILOT-Discovery.ps1` and `COPILOT-Report.ps1` to get a real baseline of broad, external, and unlabeled content before you touch anything.
- **Remediate with owners, safely.** Preview every change with `-WhatIf`, review broad grants with the content owners, and remove anonymous/org-wide links — but don't silently strip access people depend on.
- **Label the crown jewels.** Sensitivity labels are the protection Copilot honors and Copilot output inherits; prioritize labeling (and auto-labeling) your most sensitive content first.
- **Use restricted search as a temporary net.** Restricted SharePoint Search contains Copilot to curated sites while you remediate — but it also narrows legitimate search, so treat it as a bridge and lift it as sites are cleaned.
- **Layer DLP on top of labels.** A DLP-for-Copilot policy that excludes your most sensitive labels adds a second, policy-level control beyond label-based access.
- **Always pilot with a curated group.** A small `Copilot Adoption – Pilot Users – Pilot` group with license scoping catches exposure problems before the whole org can hit them.
- **Prove it with exposure probes.** The pilot gate is not "Copilot works" — it is "Copilot cannot surface what it shouldn't." Test that explicitly.
- **Govern the humans, not just the data.** Publish an acceptable-use policy, require review of AI-generated output, and name owners for governance, labels/DLP, and AI use.
- **Scope licensing to the group.** Use group-based licensing so Copilot access stays tied to the pilot group and can be rolled back by removing the group, not chasing individuals.

• **Stop the drift.** Stand up recurring access reviews and re-run discovery on a schedule so oversharing does not creep back after Copilot is live.

• **Document the cadence.** Record the remediated scope, published labels, DLP policies, and the pilot → expansion waves for audits and repeatability.

8. Deliverables Summary — Microsoft 365 Copilot Secure Adoption & Governance

Documentation

Document	Purpose
Executive Summary	Business case and what's in the box
1. Solution Overview	How Copilot reads M365 data, why oversharing is the top risk, and the controls Copilot honors
2. Requirements Guide	Every prerequisite with Verify / Implement-if-missing
Global Requirements (Security)	Category-wide prerequisites, published once
3. Implementation Guide	Exact, ordered steps: assess, remediate, labels, DLP, search controls, AI governance, pilot, expand
5. Testing Guide	Validation procedures with exposure probes and pass/fail gates
6. Troubleshooting Guide	Field issues and remediation
7. Best Practices	Field-proven recommendations

PowerShell scripts

Script	What it does
`COPILOT-Discovery.ps1`	Read-only: reports oversharing/broad access, external sharing, sensitivity-label presence, and Copilot-readiness signals
`COPILOT-Validation.ps1`	Read-only: confirms remediation held — broad links removed, labels published, Copilot licensing limited to the pilot group
`COPILOT-Report.ps1`	Read-only: data-exposure and readiness report (broadly/externally shared and unlabeled content) for the baseline and gates
`COPILOT-Remediation.ps1`	Safe remediation (default `-WhatIf`): removes anonymous/org-wide sharing links; reports broad grants for owner action

Script	What it does
`COPILOT-Set-ScopeTargeting.ps1`	Creates the `Copilot Adoption – Pilot Users – Pilot` scope group (idempotent) for controlled rollout

What the buyer receives

- This implementation guide as a branded **Word** document and **PDF**.
- All five **PowerShell scripts** in a single ZIP.
- A repeatable process following the model: **Assess** → **Configure** → **Pilot** → **Validate** → **Expand.**

Outcome

Microsoft 365 Copilot rolled out on a governed data estate — oversharing remediated first, sensitivity labels and DLP enforced so Copilot respects them, access tightened, AI use governed, and the whole thing proven on a controlled pilot with exposure probes before the fleet gets access.

Appendix A — PowerShell Scripts

Included in the accompanying ZIP. Each script's header documents full usage.

COPILOT-Discovery.ps1

Purpose: Read-only assessment of the top Microsoft 365 Copilot risk — oversharing. Enumerates SharePoint sites and (optionally) OneDrive for broad/anonymous/organization sharing links and external (guest) access, reports whether sensitivity labels exist in the tenant, and summarizes Copilot-readiness signals so you can see the data-exposure surface BEFORE enabling Copilot. Copilot returns whatever the signed-in user can access, so broad access = broad exposure. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\COPILOT-Discovery.ps1 [-Top 200] [-IncludeExternal] Requires the Microsoft Graph PowerShell SDK and consent to (read-only): Sites.Read.All, Files.Read.All, InformationProtectionPolicy.Read, Group.Read.All, User.Read.All. EXPECTED RESULTS A per-site list flagging anonymous/organization sharing links and external sharing, a count of tenant sensitivity labels (0 = labeling not started), and a readiness summary. Nothing is changed. Feed the flagged sites into COPILOT-Remediation.ps1 and COPILOT-Report.ps1. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Volatile Copilot-portal and usage-report specifics are deferred to Microsoft documentation; this script reads the sharing, label, and identity surface via Graph. #> [CmdletBinding()] param([int]$Top = 200, [switch]$IncludeExternal)

How to run: powershell -ExecutionPolicy Bypass -File .\COPILOT-Discovery.ps1 [-Top 200] [-IncludeExternal] Requires the Microsoft Graph PowerShell SDK and consent to (read-only): Sites.Read.All, Files.Read.All, InformationProtectionPolicy.Read, Group.Read.All, User.Read.All. EXPECTED RESULTS A per-site list flagging anonymous/organization sharing links and external sharing, a count of tenant sensitivity labels (0 = labeling not started), and a readiness summary. Nothing is changed. Feed the flagged sites into COPILOT-Remediation.ps1 and COPILOT-Report.ps1. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Volatile Copilot-portal and usage-report specifics are deferred to Microsoft documentation; this script reads the sharing, label, and identity surface via Graph. #> [CmdletBinding()] param([int]$Top = 200, [switch]$IncludeExternal)

COPILOT-Remediation.ps1

Purpose: Reduces the top Copilot risk (oversharing) by removing the broad sharing links that let Copilot surface content to anyone: anonymous ("anyone") links and organization-wide links on the targeted SharePoint sites. Broad group grants (e.g. "Everyone except external users") are REPORTED for owner action, not silently deleted — those often reflect legitimate access. By default it only REPORTS what it would remove (-WhatIf); pass -Apply to act. It never deletes files, unshares specific-people grants, or changes labels/DLP. HOW TO RUN Report only (default): powershell -ExecutionPolicy Bypass -File .\COPILOT-Remediation.ps1 ` -SiteUrlMatch "contoso.sharepoint.com/sites/HR" Apply: ... .\COPILOT-Remediation.ps1 -SiteUrlMatch "...HR" -Apply Requires the Microsoft Graph SDK and consent to: Sites.ReadWrite.All (to delete sharing links), Sites.Read.All. Removing links is reversible — owners can re-share to specific people. EXPECTED RESULTS A list of anonymous/org-wide links on the matched sites; with -Apply each such link is deleted so Copilot can no longer surface that content broadly. Re-run COPILOT-Validation.ps1 / COPILOT-Report.ps1 after to confirm exposure dropped. .NOTES White-label — the repeatable way. Safe by default (-WhatIf). Always preview with owners first (Implementation Step 2). Tenant-level sharing policy and label/DLP changes are done in the portals, not by this script. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param(

[Parameter(Mandatory=$true)][string]$SiteUrlMatch, [switch]$Apply)

How to run: Report only (default): powershell -ExecutionPolicy Bypass -File .\COPILOT-Remediation.ps1 ` -SiteUrlMatch "contoso.sharepoint.com/sites/HR" Apply: ... .\COPILOT-Remediation.ps1 -SiteUrlMatch "...HR" -Apply Requires the Microsoft Graph SDK and consent to: Sites.ReadWrite.All (to delete sharing links), Sites.Read.All. Removing links is reversible — owners can re-share to specific people. EXPECTED RESULTS A list of anonymous/org-wide links on the matched sites; with -Apply each such link is deleted so Copilot can no longer surface that content broadly. Re-run COPILOT-Validation.ps1 / COPILOT-Report.ps1 after to confirm exposure dropped. .NOTES White-label — the repeatable way. Safe by default (-WhatIf). Always preview with owners first (Implementation Step 2). Tenant-level sharing policy and label/DLP changes are done in the portals, not by this script. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='High')] param([Parameter(Mandatory=$true)][string]$SiteUrlMatch, [switch]$Apply)

COPILOT-Report.ps1

Purpose: Read-only. Builds the data-exposure baseline (and the re-measure after remediation) that drives the pilot and expansion gates: for the sampled SharePoint sites it counts anonymous, org-wide, and external sharing, reports how many sensitivity labels exist, and how many pilot users hold a Microsoft 365 Copilot license. Compare the baseline against a post-remediation run to prove exposure went down before Copilot is expanded. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\COPILOT-Report.ps1 ` [-Top 200] [-CopilotSkuId ""] [-CsvPath .\copilot-exposure.csv] Requires the Microsoft Graph SDK and consent to (read-only): Sites.Read.All, Files.Read.All, InformationProtectionPolicy.Read, User.Read.All, Organization.Read.All. EXPECTED RESULTS A summary: sites sampled, sites with anonymous/org-wide/external sharing, total sensitivity labels, and Copilot-licensed user count. Optional CSV of the per-site rows. Nothing is changed. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Exact per-item Copilot usage analytics are deferred to Microsoft's reporting; this reports the sharing/label/licensing exposure surface Copilot reasons over. #> [CmdletBinding()] param([int]$Top = 200, [string]$CopilotSkuId, [string]$CsvPath)

How to run: powershell -ExecutionPolicy Bypass -File .\COPILOT-Report.ps1 ` [-Top 200] [-CopilotSkuId "<Copilot SKU GUID>"] [-CsvPath .\copilot-exposure.csv] Requires the Microsoft Graph SDK and consent to (read-only): Sites.Read.All, Files.Read.All, InformationProtectionPolicy.Read, User.Read.All, Organization.Read.All. EXPECTED RESULTS A summary: sites sampled, sites with anonymous/org-wide/external sharing, total sensitivity labels, and Copilot-licensed user count. Optional CSV of the per-site rows. Nothing is changed. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. Exact per-item Copilot usage analytics are deferred to Microsoft's reporting; this reports the sharing/label/licensing exposure surface Copilot reasons over. #> [CmdletBinding()] param([int]$Top = 200, [string]$CopilotSkuId, [string]$CsvPath)

COPILOT-Set-ScopeTargeting.ps1

Purpose: Creates (idempotently) the Entra security group used to scope the controlled Microsoft 365 Copilot rollout, following the solution naming convention so Copilot licensing, DLP-for-Copilot, and label policies can be assigned consistently: Copilot Adoption - Pilot Users - Pilot An existing group (matched by displayName) is reused, not duplicated. Members are NOT added — add a few representative pilot users by hand per your standard. Assign Copilot licenses to this group (group-based licensing) so scope stays tied to the group and is easy to roll back. HOW TO RUN Report only (default): powershell -ExecutionPolicy Bypass -File .\COPILOT-Set-ScopeTargeting.ps1 Apply: ... .\COPILOT-Set-ScopeTargeting.ps1 -Apply

Requires the Microsoft Graph SDK and Group.ReadWrite.All. EXPECTED RESULTS The pilot scope group exists (created if missing, reused if present), with its object ID printed for use in Copilot licensing and Purview policy assignments. .NOTES White-label — the repeatable way. Safe by default (-WhatIf); pass -Apply to create the group. The display name uses ASCII hyphens; keep it verbatim across scripts, licensing, and policy assignments. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([switch]$Apply)

How to run: Report only (default): powershell -ExecutionPolicy Bypass -File .\COPILOT-Set-ScopeTargeting.ps1 Apply: ... .\COPILOT-Set-ScopeTargeting.ps1 -Apply Requires the Microsoft Graph SDK and Group.ReadWrite.All. EXPECTED RESULTS The pilot scope group exists (created if missing, reused if present), with its object ID printed for use in Copilot licensing and Purview policy assignments. .NOTES White-label — the repeatable way. Safe by default (-WhatIf); pass -Apply to create the group. The display name uses ASCII hyphens; keep it verbatim across scripts, licensing, and policy assignments. #> [CmdletBinding(SupportsShouldProcess=$true, ConfirmImpact='Medium')] param([switch]$Apply)

COPILOT-Validation.ps1

Purpose: Read-only pass/fail validation behind the Testing gates. For the sites you targeted it confirms anonymous/org-wide sharing links are gone; it confirms sensitivity labels are published; and it confirms Microsoft 365 Copilot licensing is limited to the pilot group (not the whole org). This is the evidence behind Testing Tests 1-3 before the pilot gate. HOW TO RUN powershell -ExecutionPolicy Bypass -File .\COPILOT-Validation.ps1 ` [-SiteUrlMatch "contoso.sharepoint.com/sites/HR"] ` [-PilotGroup "Copilot Adoption - Pilot Users - Pilot"] [-CopilotSkuId ""] Requires the Microsoft Graph SDK and consent to (read-only): Sites.Read.All, Files.Read.All, InformationProtectionPolicy.Read, Group.Read.All, User.Read.All. EXPECTED RESULTS PASS for: no anonymous/org-wide links on the matched sites; sensitivity labels published; Copilot licenses only on members of the pilot group. Any FAIL points to the matching Troubleshooting section (A oversharing / B labels / E licensing). Nothing is changed. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. The pilot-group name uses the ASCII-hyphen naming convention; keep it verbatim across scripts and Intune/Purview assignments. #> [CmdletBinding()] param([string]$SiteUrlMatch, [string]$PilotGroup = 'Copilot Adoption - Pilot Users - Pilot', [string]$CopilotSkuId)

How to run: powershell -ExecutionPolicy Bypass -File .\COPILOT-Validation.ps1 `[-SiteUrlMatch "contoso.sharepoint.com/sites/HR"]` [-PilotGroup "Copilot Adoption - Pilot Users - Pilot"] [-CopilotSkuId "<Copilot SKU GUID>"] Requires the Microsoft Graph SDK and consent to (read-only): Sites.Read.All, Files.Read.All, InformationProtectionPolicy.Read, Group.Read.All, User.Read.All. EXPECTED RESULTS PASS for: no anonymous/org-wide links on the matched sites; sensitivity labels published; Copilot licenses only on members of the pilot group. Any FAIL points to the matching Troubleshooting section (A oversharing / B labels / E licensing). Nothing is changed. .NOTES White-label — the repeatable way. Read-only against Microsoft Graph. The pilot-group name uses the ASCII-hyphen naming convention; keep it verbatim across scripts and Intune/Purview assignments. #> [CmdletBinding()] param([string]$SiteUrlMatch, [string]$PilotGroup = 'Copilot Adoption - Pilot Users - Pilot', [string]$CopilotSkuId)